

MegTech Cybersecurity Incident Handling Policy

1. Purpose & Scope

This policy establishes MegTech’s operational framework for detecting, responding to, containing, and recovering from cybersecurity incidents. It ensures operational resilience while maintaining compliance with European Union General Data Protection Regulation (GDPR) mandates.

This policy applies to all MegTech employees, contractors, third-party vendors, and technical infrastructure (cloud, on-premises, and remote environments).

2. Incident Severity Classification Matrix

Level	Severity	Description	Examples	GDPR Impact
P1	Critical	Major disruption to core business operations; confirmed loss or unauthorized access to sensitive/large-scale personal data.	Ransomware across critical systems, database exfiltration.	High risk to rights and freedoms. Mandatory DPA & Data Subject reporting.
P2	High	Significant system impairment; localized compromise of Personal Identifiable Information (PII).	Compromised administrator account, unauthorized access to internal HR files.	Potential risk to rights and freedoms. DPA reporting likely required.
P3	Medium	Minor disruption; isolated security events without verified PII	Malware isolated on a single workstation, credential stuffing	Low risk. Document in internal logs; DPA reporting usually not

		exposure.	attempt blocked.	required.
P4	Low	Near-misses, non-critical policy violations, or suspicious activity.	Phishing report, unauthorized software installation attempt.	No PII impact. Internal documentation only.

3. Incident Response Lifecycle

Phase 1: Identification & Escalation

1. **Reporting:** Any employee or vendor who suspects a security event must immediately report it to security@megtech.com or the internal Incident Helpline.
2. **Triaging:** The Security Operations Center (SOC) verifies the alert within **30 minutes** to determine authenticity and severity level.
3. **Clock Initiation:** If the incident involves personal data, the official **GDPR 72-Hour Clock** begins the moment MegTech establishes reasonable certainty of a breach.

Phase 2: Containment & Evidence Preservation

1. **Short-Term Containment:** Isolate affected endpoints, revoke compromised credentials, and restrict network routes to stop ongoing data exfiltration.
2. **Forensic Preservation:** Capture volatile memory, take system snapshots, and preserve server/network logs before restarting systems.
3. **Evidence Integrity:** Maintain a strict Chain of Custody for all digital forensic data.

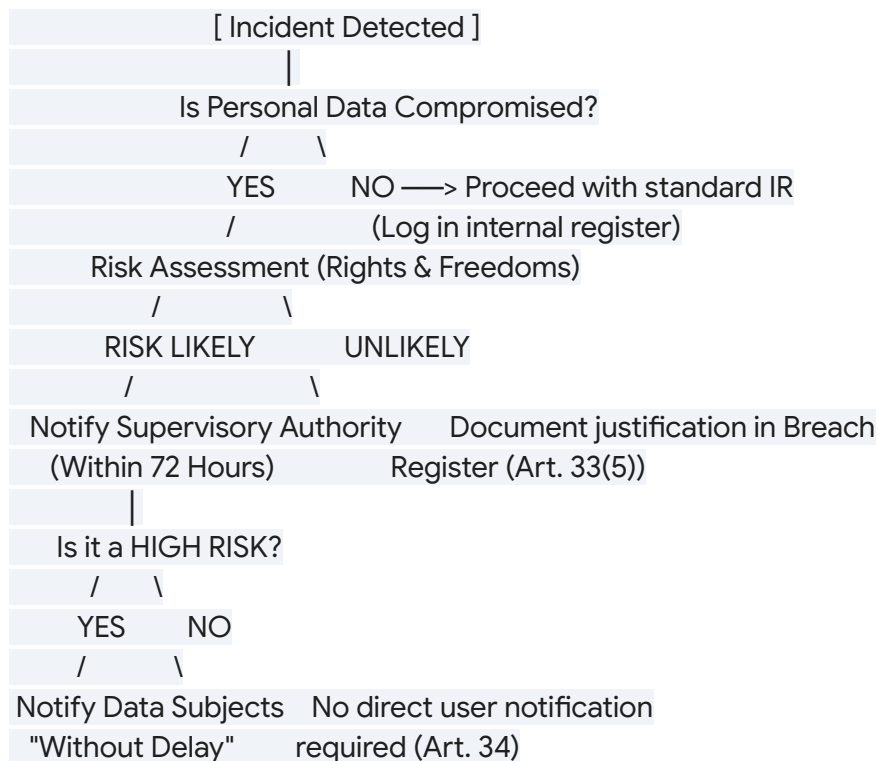
Phase 3: Eradication & Recovery

1. **Eradication:** Identify the root cause, remove malicious artifacts (e.g., backdoors, malware), and patch vulnerabilities exploited during the entry.
2. **Recovery:** Restore systems from clean, verified backups; validate integrity through security scanning before restoring access to production environments.

Phase 4: Post-Incident Activity

1. **Lessons Learned:** Conduct a post-incident review meeting within **5 business days** of incident closure.
2. **Root Cause Analysis (RCA):** Publish an RCA report detailing timeline, impact, and corrective actions.

4. GDPR Compliance & Data Breach Handling



4.1 Supervisory Authority Notification (Art. 33)

- **Timeline:** Report to the lead Data Protection Authority (DPA) **within 72 hours** of becoming aware of the breach.
- **Phased Submissions:** If complete details cannot be provided within 72 hours, submit an initial notification with available information and follow up in phases.
- **Mandatory Submission Details:**
 - Nature of the breach (categories and estimated number of data subjects/records involved).
 - Contact details of MegTech's Data Protection Officer (DPO).
 - Likely consequences of the breach.
 - Containment and remediation measures taken or planned.

4.2 Data Subject Notification (Art. 34)

- **Trigger:** Required when the breach is likely to result in a **high risk** to the rights and freedoms of individuals (e.g., financial fraud, identity theft, exposure of special category data).
- **Timeline:** Communicated **without undue delay** using plain, clear language.
- **Exceptions:** Direct notification is exempt if:
 1. The data was rendered unintelligible (e.g., strong end-to-end encryption).
 2. Subsequent actions mitigated the high risk.
 3. Individual communication would involve disproportionate effort (a public communication may be substituted).

4.3 Internal Breach Register (Art. 33(5))

MegTech maintains a centralized Internal Breach Register documenting **all** incidents—regardless of whether they met the threshold for regulatory notification. Records must include incident facts, impacts, assessment metrics, and corrective measures taken.

5. Roles & Responsibilities

Role	Primary Incident Responsibilities
Incident Response Commander	Oversees overall containment strategy, assigns technical workflows, and manages the incident lifecycle.
Data Protection Officer (DPO)	Conducts GDPR risk assessments, determines notification requirements, and leads communications with DPAs.
Lead Security Analyst / Forensics	Investigates technical vector, performs malware analysis, collects digital evidence, and executes eradication.
Legal Counsel	Advises on regulatory exposure, evaluates liability, and approves formal external notices.
PR & Corporate Communications	Drafts external press updates and handles customer queries to ensure consistent communication.

6. Training, Testing, & Policy Review

- **Tabletop Exercises:** The Incident Response Team must conduct simulated breach exercises **at least bi-annually**.
- **Employee Awareness:** Mandatory security awareness training covering phishing identification and incident reporting is conducted annually for all staff.
- **Policy Audits:** This policy is subject to review annually or immediately following any P1 incident.